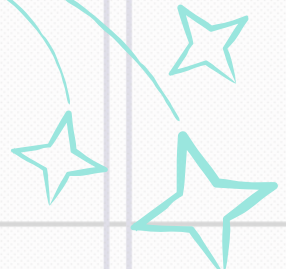


Analisis y planificacion del pentest.

**Hcker Women Council -
Ethical Hacking**



Por: Karime Yañez Bautista.



Objetivos

1. Conocer el nivel de exposición de la app web

La empresa Aurora Market busca conocer que tan expuesta se encuentra su app ante posibles ataques.

2. Identificar los riesgos, como afectarían a la empresa y las medidas para reducirlos.

Aurora Market quiere entender los riesgos que corre la empresa, como afectarían a la empresa y que medidas deben tomar para reducirlos.

3. Hacer la evaluación sin interrumpir el funcionamiento de la plataforma y en horarios de menor actividad

Las condiciones que establece la empresa indican que la evaluación debe hacerse únicamente en la aplicación web autorizada, no se puede interrumpir el funcionamiento de la plataforma ni afectar los datos reales de los clientes, de igual forma hacer la evaluación en los horarios de menor actividad para reducir el impacto en sus operaciones.





Alcance

La empresa establece que la evaluación se realizará únicamente sobre la aplicación web autorizada.

Funcionalidades de los clientes: registro, inicio de sesión, catálogo de productos, carrito de compras e historial de pedidos.

Mecanismos de autenticación y control de acceso a bases de datos: problemas de la aplicación, de permisos o una configuración incorrecta.

Fuera del alcance

No se permite atacar las redes sociales de la empresa.

Equipos personales de los empleados, correos,

proveedores externos ni otros sistemas que no formen parte del alcance acordado.

Permisos requeridos

Autorización de Aurora Market.

Utilizar la información que tenemos disponible para conocer que podría descubrir un atacante con la misma información.

Acceso a conocimiento de la aplicación web, bases de datos, mecanismos de autenticación y diferentes tipos de usuarios.



Condiciones acordadas.

Unicamente debe realizarse sobre la aplicación web.

No está permitido realizar acciones que afecten el funcionamiento de la aplicación o afectar la información real de los clientes.

Las pruebas deben realizarse en horarios de menor actividad para reducir cualquier impacto posible sobre sus operaciones.

Documentar cuidadosamente cualquier problema encontrado para que pueda ser revisado por el equipo de desarrollo de Aurora Market

Tipo de pentest

Es un pentest gary - box. Ya que Aurora Market al comenzar no entrega toda la información técnica de su infraestructura.

El equipo de pentest unicamente sabe que existe una aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios. Pero no se conoce los detalles de como está construida la plataforma ni que tecnologías usa.

Por lo que el equipo con la información disponible, el equipo debe actuar como un atacante y descubrir el alcance que podría tener el atacante con dicha información





Planificación

- **OBJETIVOS:** Identificar vulnerabilidades web, investigar la causa de fuga de información y proponer medidas para prevenir.
- **ALCANCE:** Evaluar únicamente la aplicación web de Aurora Market (frontend, backend y panel administrativo); excluyendo redes sociales, correos y sistemas externos.
- **PERMISOS Y CONDICIONES:** Contar con autorización escrita, operar en horarios de menor tráfico y evitar acciones que afecten el funcionamiento de la plataforma .
- **METODOLOGÍA A UTILIZAR:** OWASP
- **RECOPIACIÓN DE INFORMACIÓN PREVIA:** Mapeo del sitio web, revisión de tipos de usuarios, flujos de autenticación y datos expuestos.
- **RECURSOS NECESARIOS:** Credenciales de prueba (clientes y administradores), herramientas de análisis web.
- **PROGRAMACIÓN DEL PENTEST:** Cronograma con fechas fijas, horarios de prueba nocturnos o de bajo tráfico, y entrega del reporte final.

Planificación

1. **RECONOCIMIENTO:** Identificar la estructura del sitio, tecnologías web, formularios de inicio de sesión de Aurora Market.
 2. **ANÁLISIS DE VULNERABILIDADES:** buscar fallas en el control de acceso, cookies, autenticación y posibles vulnerabilidades.
 3. **EXPLOTACIÓN:** Intentar acceder a datos o funciones no autorizadas simulando el ataque para confirmar si un usuario puede ver datos de otra cuenta.
- 

4. POST-EXPLOTACIÓN: Determinar el impacto real al comprometer la cuenta.

5. INFORME: Documentar detalladamente los hallazgos, el nivel de riesgo de cada falla descubierta y las recomendaciones para remediar la seguridad para que sea revisado por el equipo de desarrollo de Aurora Market.

Planificación

La metodología elegida fue la de OWASP. Ya que es la que está 100% especializada en aplicaciones web. Se enfoca en probar controles de acceso, autenticación, gestión de sesiones e inyecciones. Lo que es muy útil y es lo que necesitamos para este pentest.

